

RÉFÉRENTIEL DES LOGS JOURNALISATION

Septembre 2021



L'article L. 122-5 de la propriété intellectuelle n'autorisant pas les représentations ou reproduction intégrale, ou partielle, faite sans le consentement de l'auteur ou de l'ayant droit ou ayant cause, sauf exception stricte (« copies ou reproductions réalisées à partir d'une source licite et strictement réservées à l'usage privé du copiste et non destinées à une utilisation collective », analyses et les courtes citations dans un but d'exemple et d'illustration, etc.), toute représentation ou reproduction, par quelque procédé que ce soit du présent document sans autorisation préalable du Clusif constituerait une contrefaçon sanctionnée par les articles L. 335-2 et suivants du Code de la propriété intellectuelle.

Table des matières

RÉFÉRENTIEL DES LOGS.....	1
JOURNALISATION	1
1. Introduction.....	6
1.1. Description du sujet.....	6
1.3. À qui s'adresse ce document ?.....	6
1.2. Objectifs du document.....	6
2. Définitions.....	7
2.1. Principales notions	7
2.1.1. Données à caractère personnel.....	7
2.1.2. Logs ou traces.....	7
2.1.3. Journalisation	7
2.1.4. Horodatage	8
2.1.5. Cookies	8
2.1.6. Adresse IP.....	9
2.2. Les principes relatifs aux traitements de données à caractère personnel	9
3. La finalité des logs : une nécessité de détection et d'analyse des incidents de sécurité ..	10
3.1. Une obligation légale	10
3.1.1. Le cadre juridique français.....	10
3.1.2. Le cadre juridique européen	12
3.2. Une finalité de sécurité : tracer les accès et gérer les incidents	14
3.2.1. L'information des personnes concernées (collaborateurs, utilisateurs externes, invités, etc.)	14
3.2.2. Organiser une collecte des événements de sécurité.....	16
3.2.3. Détecter les événements anormaux ou inhabituels	16
3.2.4. Analyser et qualifier les incidents.....	16
3.2.5. Être en mesure de reconstituer le scénario des incidents et leur étendue	17
3.2.6. Intervenir et notifier.....	17
3.3. La valeur probatoire des éléments de journalisation	18
4. Informations sur les mentions légales	18
4.1. Cadre juridique	18
4.2. Gestion de la sous-traitance	18
4.3. Destinataires des données	19
5. Durée de conservation des données	19
6. Les risques liés à la mise en place d'une journalisation	21

6.1.	Le détournement de finalité, conséquence d'une utilisation inappropriée d'un élément du SI	22
6.2.	Contrôle de l'utilisation d'Internet et de la messagerie	23
7.	Exemples de cas particuliers	24
7.1.	Opérateur de service essentiel (OSE) et fournisseur de service numérique (FSN)	24
7.2.	Fournisseurs d'accès d'Internet (FAI)	25
7.3.	Protection de la création sur Internet – Cas Hadopi	26
8.	Pour aller plus loin	28
9.	Acronymes	29

Remerciements

Le **Clusif** tient à mettre ici à l'honneur les personnes qui ont rendu possible la réalisation de ce document, tout particulièrement :

Le responsable du groupe de travail :

Thomas **VAN DEN HEUVEL** Agence de la biomédecine

Les contributeurs :

Grégory	ADROT	Armand Thiery
Aline	ALFER	Mathias Avocats
Patrick	BLUM	Clusif
Afaf	FAFI	CONIX
Fabrice	IDIER	Conseil départemental de la Seine Saint-Denis
Garance	MATHIAS	Mathias Avocats
Fabrice	POLLART	Maisons et Cités

Le **Clusif** remercie également les adhérents ayant participé à la relecture.

1. Introduction

1.1. Description du sujet

De nombreux journaux contiennent des informations relatives à la sécurité informatique. Ces journaux sont générés par différentes sources telles que des éléments de sécurité (logiciels antivirus, pare-feu, systèmes de détection et de prévention des intrusions, etc.) mais aussi par les systèmes d'exploitation d'équipements utilisés pour des besoins non sécuritaires (serveurs, postes de travail, équipements de réseau, équipements nomades, etc.) et les applications (messagerie, navigation Internet, application métier, etc.).

Le recueil des logs ou des traces est utilisé dans le cadre de la sécurité informatique, mais pas uniquement. La gestion des logs peut avoir d'autres finalités (statistiques, surveillance des systèmes, facturation, etc.), mais ces usages ne seront pas traités ici.

Ce document propose un focus sur les journaux liés à la sécurité informatique et contenant des données à caractère personnel.

Le processus de génération, de transmission, de stockage, d'analyse et d'élimination des données des journaux de sécurité informatique représente un enjeu vis-à-vis du respect de la réglementation en vigueur, et notamment du règlement européen sur la protection des données (RGPD, également dénommé « règlement européen » dans la suite du document). Les enregistrements de sécurité informatique doivent être stockés de manière suffisamment détaillée pendant une période appropriée. La gestion des journaux implique également la protection de la confidentialité, de l'intégrité et de la disponibilité de ces journaux.

1.2. Objectifs du document

Au regard de ce contexte, le présent document a pour objectif de permettre à toute personne amenée à traiter des données d'appréhender la multiplicité et les spécificités des exigences légales ou réglementaires applicables dans ce domaine, de manière pragmatique et accessible.

Il représente ainsi une déclinaison sectorielle de la série de fiches thématiques (FAQ) mise à disposition par le Clusif visant à expliciter les grandes notions du règlement européen et à apporter des réponses concrètes concernant le traitement des données à caractère personnel. Décliné sous forme de fiches pratiques, il contient les premiers éléments de réponse sur une thématique définie afin de permettre d'identifier les principales questions juridiques liées au traitement des données de journalisation et acquérir ainsi les bons réflexes en matière de gestion des exigences légales et réglementaires.

Enfin, ce document a pour ambition de fournir les clés de lecture du cadre juridique applicable dans ce domaine en matière de sécurité de l'information et de délivrer les points de vigilance afférents. Il n'a toutefois pas de prétention d'exhaustivité et ne dispense pas de recourir à un conseil juridique spécialisé, qu'il soit interne ou externe à l'organisme.

1.3. À qui s'adresse ce document ?

Ce guide s'adresse à tout organisme privé ou public, ayant mis en place un système de journalisation des logs ou des traces. Il constitue ainsi un document de référence pour chaque personne souhaitant déployer ou ayant la responsabilité d'intégrer, au sein de son organisme, un système de journalisation des logs ou des traces, ou susceptible de traiter ces données.

2. Définitions

2.1. Principales notions

2.1.1. Données à caractère personnel

Constitue une **donnée personnelle** « *toute information se rapportant à une personne physique identifiée ou identifiable¹ (dénommée *personne concernée*)* ». Une personne physique identifiable peut être identifiée « *directement ou indirectement, notamment par référence à un identifiant, tel qu'un nom, un numéro d'identification, des données de localisation, un identifiant en ligne, ou à un ou plusieurs éléments spécifiques propres à son identité physique, physiologique, génétique, psychique, économique, culturelle ou sociale* » (RGPD, art. 4.1).

Pour déterminer si une personne est identifiable, il convient de considérer l'ensemble des moyens permettant son identification, dont disposent ou auxquels peuvent avoir accès le responsable du traitement ou toute autre personne. Le règlement européen s'applique donc ici, que les données soient directement ou indirectement personnelles.

➔ Cf. Fiche FAQ « [Données personnelles, traitement, responsable de traitement](#) »

2.1.2. Logs ou traces

Selon le groupe de travail de l'Observatoire de la sécurité des systèmes d'information et des réseaux (OSSIR), ces notions peuvent être définies de la manière suivante :

- un « log » est la journalisation de données informatiques résultant de l'utilisation d'une application ;
- une « trace » est une donnée informatique témoignant de l'existence d'une opération au sein d'une application.

2.1.3. Journalisation

Un log ou un journal est un enregistrement des événements qui se produisent au sein du système d'information (SI) d'une organisation. Les journaux sont composés d'entrées de journal : chaque entrée contient des informations relatives à un événement spécifique qui s'est produit au sein du SI (la date et l'heure de l'action, le compte utilisé lors de l'action, le client à l'origine de l'action, la ressource sollicitée, etc.).

Les journaux peuvent être utilisés pour détecter des incidents en quasi-temps réel (corrélation ou *monitoring*) et *a posteriori*.

La Commission nationale de l'informatique et des libertés (Cnil) précise qu'un dispositif de gestion des traces et des incidents doit être mis en place par les organisations. Il s'agit d'une mesure de sécurité destinée à identifier un accès frauduleux ou une utilisation abusive de données personnelles. Ce dispositif doit enregistrer les événements pertinents et garantir que ces enregistrements ne peuvent être altérés. Dans tous les cas, il convient de ne pas conserver ces éléments pendant une durée excessive.

¹ Dans ce document, les mentions en italique sont des citations extraites des textes législatifs et réglementaires.

L'Agence nationale de la sécurité des systèmes d'information (Anssi) estime quant à elle que les journaux d'événements constituent une brique technique indispensable à la gestion de la sécurité des SI. Les journaux sont une source d'information riche qui peut être utilisée pour détecter des incidents de sécurité, ou pour retrouver les traces d'un incident de sécurité.

L'activité de journalisation constitue donc un moyen de détection et d'analyse.

2.1.4. Horodatage

L'horodatage permet d'attester qu'une donnée existe à un instant déterminé.

- Il n'existe pas de trace (fiable) sans horodatage :

Chaque équipement informatique fait généralement référence à son horloge interne lorsqu'il définit un horodatage pour chaque entrée de journal. Si l'horloge est inexacte, les horodatages des journaux le seront également. Cela peut rendre l'analyse des journaux plus difficile ou erronée, notamment lors de l'analyse de journaux provenant de plusieurs équipements qui ne s'appuient pas sur la même référence de temps.

- Il n'y a pas de corrélation sans synchronisation :

La mobilité et les SI situés sur plusieurs fuseaux horaires complexifient la corrélation des données issues des différents journaux. Si les horloges des systèmes ne peuvent pas être synchronisées entre elles, l'usage de technologies de synchronisation telles que les serveurs NTP (*Network Time Protocol*) apparaît primordial afin de maintenir la cohérence des horloges des sources de journalisation.

Pour l'Anssi, « Une précision d'une seconde est largement suffisante pour toutes les applications [...]. En l'état actuel de la technique, un horodatage bien meilleur que 10 millisecondes n'aurait pas grand sens² ».

2.1.5. Cookies

« Un cookie est un petit fichier stocké par un serveur dans le terminal (ordinateur, téléphone, etc.) d'un utilisateur et associé à un domaine web (c'est-à-dire dans la majorité des cas à l'ensemble des pages d'un même site web). Ce fichier est automatiquement renvoyé lors de contacts ultérieurs avec le même domaine³. »

Les traitements de données à caractère personnel générés par les cookies bénéficient d'un cadre légal spécifique issu de la directive e-Privacy⁴ et transposé en droit français à l'article 82 de la loi Informatique et Libertés (LIL)⁵.

La Cnil recommande que la simple poursuite de la navigation sur un site web ne soit pas regardée comme une expression valide du consentement au dépôt de cookies, lequel doit résulter d'un acte positif univoque de l'internaute⁶.

➡ Cf. Fiches FAQ « Cookie et traceurs » et « Le consentement au traitement des données personnelles »

² Anssi. Référentiel général de sécurité, version 2.0. 2014.

³ <https://www.cnil.fr/fr/definition/cookie>

⁴ Directive 2002/58/CE du Parlement européen et du Conseil du 12 juillet 2002 concernant le traitement des données à caractère personnel et la protection de la vie privée dans le secteur des communications électroniques (directive vie privée et communications électroniques), modifiée en 2009.

⁵ Loi n° 78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés.

⁶ <https://www.cnil.fr/fr/cookies-et-autres-traceurs-la-cnil-publie-des-lignes-directrices-modificatives-et-sa-recommandation>

2.1.6. Adresse IP

« La communication sur l'Internet est fondée sur un protocole appelé IP pour Internet Protocol qui permet aux ordinateurs de communiquer entre eux. Ce protocole utilise des adresses numériques pour distinguer ces machines et tronçonne la communication en paquets comportant chacun une adresse de source et une adresse de destination⁷. »

De par ses considérants, le RGPD rappelle que des adresses IP et cookies peuvent être associés aux personnes physiques :

*« (30) Les personnes physiques peuvent se voir associer, par les appareils, applications, outils et protocoles qu'elles utilisent, des identifiants en ligne tels que **des adresses IP et des témoins de connexion (« cookies »)** ou d'autres identifiants, par exemple des étiquettes d'identification par radiofréquence. Ces identifiants peuvent laisser des traces qui, notamment lorsqu'elles sont combinées aux identifiants uniques et à d'autres informations reçues par les serveurs, peuvent servir à créer des profils de personnes physiques et à identifier ces personnes. »*

Le règlement européen a renforcé les exigences en matière de validité du consentement⁸.

2.2. Les principes relatifs aux traitements de données à caractère personnel

Le recueil des logs ou des traces constitue un traitement de données à caractère personnel. Il doit donc être envisagé comme tel et respecter les principes définis par le règlement européen (RGPD, art. 5) :

Les données à caractère personnel doivent ainsi être :

- a) traitées de manière licite, loyale et transparente au regard de la personne concernée (**licéité, loyauté, transparence**) ;
 - b) collectées pour des finalités déterminées, explicites et légitimes, et ne pas être traitées ultérieurement d'une manière incompatible avec ces finalités (**limitation des finalités**) ;
 - c) adéquates, pertinentes et limitées à ce qui est nécessaire au regard des finalités pour lesquelles elles sont traitées (**minimisation des données**) ;
 - d) exactes et, si nécessaire, tenues à jour ; toutes les mesures raisonnables doivent être prises pour que les données à caractère personnel qui sont inexactes, eu égard aux finalités pour lesquelles elles sont traitées, soient effacées ou rectifiées sans tarder (**exactitude**) ;
 - e) conservées sous une forme permettant l'identification des personnes concernées pendant une durée n'excédant pas celle nécessaire au regard des finalités pour lesquelles elles sont traitées (**limitation de la conservation**) ;
 - f) traitées de façon à garantir une sécurité appropriée des données à caractère personnel, y compris la protection contre le traitement non autorisé ou illicite et contre la perte, la destruction ou les dégâts d'origine accidentelle, à l'aide de mesures techniques ou organisationnelles appropriées (**intégrité et confidentialité**).
- ➡ Cf. Fiche FAQ « Quels sont les principes du RGPD ? »

⁷ <https://www.ssi.gouv.fr/administration/glossaire/p/#protocole-ip>

⁸ Lignes directrices 5/2020 sur le consentement au sens du règlement (UE) 2016/679, adoptées le 4 mai 2020

3. La finalité des logs : une nécessité de détection et d'analyse des incidents de sécurité

La collecte de certaines données permet d'assurer la sécurité des services et de détecter, d'éviter ou de retracer toute tentative de malveillance ou d'intrusion informatique ou toute violation de données, humaine ou non :

- les journaux de logs sont une source d'information qui peut être utilisée pour détecter des incidents de sécurité ;
- les événements constituant les journaux peuvent être consultés et analysés soit en temps réel, soit employés *a posteriori* pour retrouver les éléments permettant d'assurer la traçabilité d'un incident de sécurité ;
- l'analyse des journaux d'un ensemble de composants (postes de travail, équipements réseau, serveurs, etc.) peut permettre de traiter les incidents et ainsi de comprendre le cheminement d'une attaque et d'évaluer son impact ;
- les journaux tracent les actions telles qu'elles se sont réalisées et peuvent servir de valeur probatoire en cas de réquisition ou de conflit.

La finalité peut résulter d'une obligation légale, ou d'un besoin légitime de sécurité (*RGPD, art. 6*).

La collecte de logs peut avoir diverses finalités : répondre à une obligation légale, assurer la sécurité du système d'information mais aussi surveiller l'activité des utilisateurs, réaliser des statistiques, etc.

3.1. Une obligation légale

3.1.1. Le cadre juridique français

L'obligation de conservation des données de connexion est prévue par deux textes : [l'article L. 34-1 du Code des postes et des communications électroniques](#) (CPCE) et [l'article 6 de la loi n° 2004-575 du 21 juin 2004 pour la confiance dans l'économie numérique](#) (LCEN). Le corollaire de cette obligation de conservation est celle de donner accès aux traces aux autorités judiciaires ou administratives lorsqu'elles en font la demande.

L'article L. 34-1 du CPCE

Le point III de l'article L. 34-1 du CPCE prévoit une obligation de conservation des données de connexion pour une durée de un an à la charge des opérateurs et des fournisseurs de services de communications électroniques, ainsi que de toute personne fournissant un accès Internet au public à des fins de la recherche, de la constatation et de la poursuite des infractions pénales.

Adopté par [le décret n° 2006-358 du 24 mars 2006](#), le point I de [l'article R. 10-13 du CPCE](#) précise quelles sont les données à conserver :

- « a) Les informations permettant d'identifier l'utilisateur ;
 b) Les données relatives aux équipements terminaux de communication utilisés ;
 c) Les caractéristiques techniques ainsi que la date, l'heure et la durée de chaque communication ;
 d) Les données relatives aux services complémentaires demandés ou utilisés et leurs fournisseurs ;
 e) Les données permettant d'identifier le ou les destinataires de la communication. »

Le point II de l'article R. 10-13 du CPCE prévoit en outre que, pour les activités de téléphonie, l'opérateur doit conserver, en plus des données précitées, les données « *permettant d'identifier l'origine et la localisation de la communication* ».

L'article 6 de la LCEN

Le point II de l'article 6 de loi du 21 juin 2004 prévoit également une obligation de conservation des données par les fournisseurs d'accès à Internet (FAI). [Le décret n° 2011-219 du 25 février 2011](#) décrit les données devant être conservées par ces fournisseurs pour une durée de un an :

- Les données de connexion :
 - « a) *l'identifiant de la connexion,*
 - b) *l'identifiant attribué par ces personnes à l'abonné,*
 - c) *l'identifiant du terminal utilisé pour la connexion lorsqu'elles y ont accès,*
 - d) *les dates et heures de début et de fin de la connexion,*
 - e) *les caractéristiques de la ligne de l'abonné* » ;
- Les données d'identification :
 - « Au moment de la création du compte, l'identifiant de cette connexion :
 - a) *les nom et prénom ou la raison sociale,*
 - les adresses postales associées,
 - b) *les pseudonymes utilisés,*
 - c) *les adresses de courrier électronique ou de compte associé,*
 - d) *les numéros de téléphone,*
 - e) *le mot de passe ainsi que les données permettant de le vérifier ou de le modifier, dans leur dernière version mise à jour* ».

La qualification du fournisseur d'accès à Internet : exemples jurisprudentiels

Dans un **arrêt du 4 février 2005**⁹, la cour d'appel de Paris a retenu la qualité de fournisseur d'accès au réseau de la société BNP Paribas. Deux collaborateurs d'une société avaient reçu un courriel malveillant. L'arrêt énonce que le traçage des messages litigieux au moyen de l'adresse IP a permis à la société d'identifier un ordinateur situé dans les locaux de la société BNP Paribas. Cette dernière n'a pas répondu aux demandes de communication de l'identité de l'expéditeur ou de toutes informations permettant de l'identifier.

Après avoir qualifié la société BNP Paribas de « prestataire technique », la cour a conclu que la société BNP Paribas était tenue de conserver les données de nature à permettre l'identification de toute personne ayant contribué à la création d'un contenu dont elle est prestataire, et de communiquer ces données sur réquisition judiciaire.

Dans un [arrêt du 15 septembre 2016, Tobias Mc Fadden c. Sony Music Entertainment Germany GmbH](#), la Cour de justice de l'Union européenne (CJUE) a jugé que le gérant d'une boutique qui proposait à ses clients un accès Internet *via* un Wi-Fi gratuit et anonyme avait la qualité de fournisseur d'accès à Internet.

Ainsi, les juges français et européens ont une interprétation large de la qualité de fournisseur d'accès à Internet. Il en résulte notamment que les organismes employeurs sont tenus de stocker les données de connexions de leurs employés ou invités. Il en va de même pour les commerçants qui fournissent à leurs clients un accès Wi-Fi, qu'il soit gratuit ou payant.

⁹ CA Paris, 14^e chambre, Section B, RG 04/20 259, 4 février 2005.

3.1.2. Le cadre juridique européen

Au niveau européen, la [directive 2006/24/CE du 15 mars 2006](#) sur la conservation de données générées ou traitées dans le cadre de la fourniture de services de communications électroniques accessibles au public ou de réseaux publics de communications et modifiant la directive 2002/58/CE¹⁰ prévoit, dans son article 3 paragraphe 1, une obligation de conservation des données à la charge de fournisseurs de services de communications électroniques accessibles au public ou d'un réseau public de communications. Ces dispositions ont été transposées en droit français à l'article L. 34-1 du CPCE (cf. précédemment).

Les catégories de données à conserver sont énumérées à l'article 5 de la directive. Sont concernées les données nécessaires pour :

- retrouver et identifier la source d'une communication,
- identifier la destination d'une communication,
- déterminer la date, l'heure et la durée d'une communication,
 - déterminer le type de communication,
 - identifier le matériel de communication des utilisateurs ou ce qui est censé être leur matériel,
- localiser le matériel de communication.

Droit européen et conservation généralisée et indifférenciée des données de trafic

Dans un [arrêt du 8 avril 2014, concernant les affaires jointes Digital Rights Ireland Ltd \(C-292/12\) et Kärntner Landesregierung \(C-594/12\)](#), la Cour de justice de l'Union européenne (CJUE) a invalidé l'obligation de conservation prévue par la directive 2006/24/CE, en estimant qu'une telle obligation générale de conservation des données relatives au trafic et aux données de localisation constituait une ingérence disproportionnée au respect de la vie privée et à la protection des données à caractère personnel.

Dans un [arrêt du 21 décembre 2016, portant sur les affaires jointes Tele2 Sverige AB \(C-203/15\) et Secretary of State for the Home Department \(C-698/15\)](#), la CJUE a rappelé que « le droit de l'Union s'oppose à une conservation généralisée et indifférenciée des données relatives au trafic et des données de localisation ». La CJUE a toutefois énoncé des conditions pour que la mise en place d'une obligation de conservation soit admise.

Dans un [arrêt du 2 octobre 2018, Ministerio fiscal \(C-207/16\)](#), la CJUE a jugé que « les infractions pénales qui ne sont pas d'une particulière gravité peuvent justifier un accès aux données à caractère personnel conservées par des fournisseurs de services de communications électroniques dès lors que cet accès ne porte pas une atteinte grave à la vie privée ». Autrement dit, si l'ingérence à la vie privée n'est pas importante, les autorités peuvent accéder aux données même en cas d'infractions non graves.

Certaines associations, dont la Quadrature du Net ont saisi le Conseil d'État par une [requête introductive d'instance du 1^{er} septembre 2015](#). Le Conseil d'État a sursis à statuer et transmis un certain nombre de questions préjudicielles à la CJUE dans une [décision du 26 juillet 2018](#).

Dans un [arrêt du 6 octobre 2020](#)¹¹, la CJUE a énoncé que le droit européen s'oppose à ce qu'une législation nationale prévoie, à titre préventif, une conservation généralisée et indifférenciée des données relatives au trafic et des données de localisation à des fins judiciaires ou de renseignement. Une telle obligation constitue donc, selon la cour de Luxembourg, une ingérence dans le droit au respect de la vie privée. Peu importe que les données relèvent ou non de catégories particulières de données et qu'elles soient utilisées ou non.

¹⁰ directive 2002/58/CE du Parlement européen et du Conseil du 12 juillet 2002 concernant le traitement des données à caractère personnel et la protection de la vie privée dans le secteur des communications électroniques (directive vie privée et communications électroniques).

¹¹ CJUE, Aff. jointes C-511/18, C-512/18 et C-520/18, 6 octobre 2020.

Cela étant, la CJUE a tout de même apporté des tempéraments à ce principe (injonction de conservation généralisée et indifférenciée en cas de menace grave pour la sécurité nationale sous réserve d'un contrôle juridictionnel ou par une autorité administrative indépendante, conservation ciblée des données aux fins de sauvegarde de la sécurité nationale, de la lutte contre la criminalité grave et de la prévention des menaces graves contre la sécurité publique, etc.).

Droit européen et conservation généralisée et indifférenciée des données de trafic (suites)

Le 2 mars 2021¹², la CJUE a de nouveau statué en la matière et il ressort de l'arrêt que le droit européen :

- « [...] s'oppose à une réglementation nationale permettant l'accès d'autorités publiques à un ensemble de données relatives au trafic ou de données de localisation, susceptibles de fournir des informations sur les communications effectuées par un utilisateur d'un moyen de communication électronique ou sur la localisation des équipements terminaux qu'il utilise et de permettre de tirer des conclusions précises sur sa vie privée, à des fins de prévention, de recherche, de détection et de poursuite d'infractions pénales, sans que cet accès soit circonscrit à des procédures visant à la lutte contre la criminalité grave ou à la prévention de menaces graves contre la sécurité publique, ce indépendamment de la durée de la période pour laquelle l'accès auxdites données est sollicité et de la quantité ou de la nature des données disponibles pour une telle période. »

À l'occasion de cet arrêt, la CJUE a également précisé qu'au regard du droit européen, le ministère public (autrement appelé « parquet » en France) ne peut avoir compétence pour autoriser l'accès d'une autorité publique aux données relatives au trafic et aux données de localisation dans le cadre d'une procédure pénale. En substance, le ministère public ne peut à la fois diriger l'enquête, mener l'action publique dans le cadre de poursuites ultérieures et autoriser l'accès aux données.

Position du Conseil d'État du 21 avril 2021¹³

« La conservation généralisée des données est aujourd'hui justifiée par la menace existante pour la sécurité nationale. » Le Conseil d'État relève également que « la possibilité d'accéder à ces données pour la lutte contre la criminalité grave permet, à ce jour, de garantir les exigences constitutionnelles de prévention des atteintes à l'ordre public et de recherche des auteurs d'infractions pénales ». En revanche, il ordonne au Gouvernement de « réévaluer régulièrement la menace qui pèse sur le territoire pour justifier la conservation généralisée des données et de subordonner l'exploitation de ces données par les services de renseignement à l'autorisation d'une autorité indépendante ».

Le Conseil d'État juge illégale l'obligation de conservation généralisée des données (hormis les données peu sensibles : état civil, adresse IP, comptes et paiements) pour les besoins autres que ceux de la sécurité nationale, notamment la poursuite des infractions pénales.

Enfin, il ordonne au Premier ministre de modifier le cadre réglementaire, à savoir mettre en œuvre un avis contraignant de la Commission nationale de contrôle des techniques de renseignement (CNCTR).

¹² CJUE, Aff. C-746/18, 2 mars 2021

¹³ [CE, 21 avril 2021, Association La Quadrature du Net et autres](#)

À ce stade, il convient de rappeler que les opérateurs de services de communications électroniques doivent respecter les obligations qui leur incombent en vertu du RGPD en ce qui concerne la collecte et la conservation ou tout autre traitement des données de connexion.

Du point de vue du DPO :

La journalisation mise en œuvre dans une application n'est pas un traitement en tant que tel et ne sera pas remontée dans le registre de traitement (c'est une mesure de sécurité des traitements).

Du point de vue du RSSI :

La journalisation permet dans le cas de sinistres, d'incidents de sécurité, de violation des accès ou dans le cas d'un contrôle par une autorité (Cnil, par exemple) de fournir les preuves nécessaires à l'établissement des responsabilités.

3.2. Une finalité de sécurité : tracer les accès et gérer les incidents

Dans un contexte de cybermenace, il devient indispensable de disposer d'une chaîne opérationnelle de gestion des incidents permettant de collecter les événements de sécurité et d'intervenir si nécessaire.

3.2.1. L'information des personnes concernées (collaborateurs, utilisateurs externes, invités, etc.)

Les personnes dont les données personnelles font l'objet d'un traitement doivent être informées des caractéristiques de ce dernier conformément aux articles 12 et suivants du RGPD.

Une telle information est donc due aux collaborateurs, mais aussi aux utilisateurs externes ou invités.

Ces personnes doivent être informées notamment de :

- l'identité et les coordonnées du responsable du traitement ;
- le cas échéant, les coordonnées du délégué à la protection des données (*Data Protection Officer*, DPO) ;
- les finalités poursuivies ;
- la base légale du dispositif (obligation issue du Code du travail par exemple, ou intérêt légitime de l'employeur) ;
- les catégories de données traitées (en cas de collecte indirecte) ;
- les destinataires des données ;
- la durée de conservation des données ;
- leurs droits ;
- la possibilité d'introduire une réclamation auprès de la Cnil (si non-prise en compte par le responsable de traitement).

S'agissant spécifiquement des collaborateurs, les instances représentatives du personnel doivent être informées et consultées avant la décision de mise en œuvre de moyens ou techniques permettant le contrôle de l'activité des salariés¹⁴. En tout état de cause, les personnels et leurs instances représentatives peuvent être associés à la définition des processus de mise en œuvre des mécanismes de journalisation, en particulier s'ils sont utilisés à des fins disciplinaires. Par ailleurs, quelle que soit sa nature, l'usage de la journalisation des données dans la sphère sociale doit faire l'objet d'une analyse de proportionnalité afin de vérifier qu'elle est adaptée au but recherché et qu'il n'existe pas de moyen moins intrusif de parvenir audit résultat.

Les modalités d'information peuvent varier selon les catégories de personnes concernées. Ainsi, l'information des collaborateurs peut être effectuée au moyen d'une **charte informatique** (opposable au salarié dès lors qu'elle a été annexée au règlement intérieur), d'une **note individuelle**, d'une **note de service** ou d'une **politique de protection des données** (présentée aux collaborateurs à leur arrivée, et publiée sur l'intranet de l'organisme par exemple). Les autres catégories de personnes concernées (utilisateurs externes par exemple) peuvent être informées avant la connexion au réseau (mention d'information, politique de protection des données).

Sous réserve du respect des règles rappelées dans le présent référentiel, l'entité qui met en place un système de journalisation peut analyser les logs à sa disposition pour détecter des comportements illicites ou contraires au règlement intérieur ou la charte informatique.

Dans un arrêt du 25 novembre 2020¹⁵, la chambre sociale de la Cour de cassation a admis l'utilisation des logs à titre de preuve dans le cadre d'une procédure de licenciement pour faute grave d'un salarié exerçant les fonctions de correspondant informatique et libertés [ancien DPO], au motif d'une usurpation de données informatiques, alors que la déclaration du traitement auprès de la Cnil n'avait pas été faite (*les faits datant de 2015, soit avant l'entrée en vigueur du RGPD*).

Dans cet arrêt, la cour considère que « l'illicéité d'un moyen de preuve, au regard des dispositions de la LIL, dans sa version antérieure à l'entrée en vigueur du RGPD n'entraîne pas nécessairement son rejet des débats, le juge devant apprécier si l'utilisation de cette preuve a porté atteinte au caractère équitable de la procédure dans son ensemble, en mettant en balance le droit au respect de la vie personnelle du salarié et le droit à la preuve, lequel peut justifier la production d'éléments portant atteinte à la vie personnelle d'un salarié à la condition que cette production soit indispensable à l'exercice de ce droit et que l'atteinte soit strictement proportionnée au but poursuivi ».

La cour rappelle également que l'adresse IP est une donnée à caractère personnel permettant d'identifier indirectement une personne physique.

Du point de vue du DPO :

Les traitements mis en œuvre à partir des différents systèmes de contrôle des outils informatiques doivent être inscrits au registre des activités de traitement tenu par l'employeur. Le DPO doit ainsi être associé à la mise en œuvre des dispositifs de contrôle.

¹⁴ Code du travail, article L. 2312-38.

¹⁵ Cass. soc., 25 novembre 2020, *Manfrini*, n° 17-19.523 : https://www.courdecassation.fr/jurisprudence/2/chambre_sociale/576/1119_25_45978.html

3.2.2. Organiser une collecte des événements de sécurité

Comme le précise la Cnil, l'entité doit être capable :

- d'identifier un accès frauduleux, un événement anormal ou une utilisation abusive de données personnelles ;
- de déterminer l'origine de l'événement de sécurité ;
- d'enregistrer certaines des actions effectuées sur les systèmes informatiques. Pour ce faire, il est nécessaire de mettre en place un dispositif de gestion des traces et des incidents. Celui-ci doit **enregistrer les événements pertinents** et **garantir qu'ils ne puissent être altérés**. Dans tous les cas, ils ne doivent pas **être conservés pendant une durée excessive** ;
- **d'informer les utilisateurs** de la mise en place d'un tel système, après information et consultation des représentants du personnel ;
- **de prévoir un système de journalisation** permettant un enregistrement dans des « fichiers journaux » ou « logs » des activités des utilisateurs, des anomalies et des événements liés à la sécurité :
 - ces journaux doivent conserver les événements sur une période glissante ne pouvant excéder six mois (sauf obligation légale ou risque particulièrement important, cf. 5. « Durée de conservation des données »),
 - **la journalisation doit concerner, au minimum, les accès des utilisateurs** en incluant leur identifiant, la date et l'heure de leur connexion et celles de leur déconnexion,
 - dans certains cas, il peut être nécessaire de conserver également le détail des actions effectuées par l'utilisateur, les types de données accédées et la référence de l'enregistrement concerné.

3.2.3. Détecter les événements anormaux ou inhabituels

À partir de journaux d'événements (*event logs*), il est possible de détecter des écarts par rapport à une situation normale (algorithme de traitement, intelligence artificielle, *machine learning*, etc.).

Plusieurs cas d'usages existent, notamment dans le cadre de la cybersécurité :

- détection d'intrusion ;
- détection de vulnérabilités ;
- détection de fraude ;
- détection d'exfiltration de données.

Plusieurs solutions techniques sont proposées, telles que la mise en place d'une architecture de type SIEM (*security information event management*, ou gestion des événements de sécurité).

3.2.4. Analyser et qualifier les incidents

Les analystes ne doivent rechercher et analyser que les informations **strictement nécessaires à la finalité de sécurité**. La liste des éléments qui seront recherchés et analysés est préalablement définie pour permettre de les vérifier et de les valider.

La qualification doit être effectuée au regard de l'organisme et des personnes concernées pour lesquelles des données personnelles sont recueillies.

3.2.5. Être en mesure de reconstituer le scénario des incidents et leur étendue

Les événements journalisés doivent permettre d'imputer les actions pouvant avoir un impact sur la sécurité de ses SI, afin d'identifier les événements et les responsabilités lors d'un incident. Grâce aux traces, l'organisme est capable de reconstituer le scénario d'un incident, d'en déterminer les vecteurs et de connaître les zones, informations et équipements touchés.

Cette connaissance permettra de corriger l'incident sur l'ensemble du périmètre touché mais surtout d'éviter qu'il ne se reproduise.

3.2.6. Intervenir et notifier

- Établir des procédures détaillant la surveillance de l'utilisation du traitement et **examiner périodiquement les journaux d'événements** pour y détecter d'éventuelles anomalies.
- Prévoir des procédures de traitement d'incidents afin de pouvoir réagir en cas de violation de données (atteinte à la confidentialité, l'intégrité ou la disponibilité¹⁶).
- Assurer que les gestionnaires du dispositif de gestion des traces notifient, dans les plus brefs délais, toute anomalie ou tout incident de sécurité au responsable de traitement.
- **Le cas échéant, notifier les violations de données à caractère personnel à la Cnil** et les communiquer aux personnes concernées, dans les conditions prévues par le règlement européen.
- En fonction des secteurs d'activité, **notifier aux autres organismes** (agence régionale de santé, Anssi, ACPR, etc.).

⇒ Cf. Fiche FAQ « [Qu'est-ce qu'une violation de donnée personnelle ?](#) »

Certaines précautions élémentaires doivent être mises en place au sein de l'organisme :

- **protéger les équipements de journalisation et les informations journalisées** contre les accès non autorisés, notamment en les rendant inaccessibles aux personnes dont l'activité est journalisée ;
- **ne pas détourner les finalités** : utiliser les informations issues des dispositifs de journalisation à d'autres fins que celles de garantir le bon usage du système informatique (par exemple, utiliser les traces pour compter les heures travaillées est un détournement de finalité, puni par la loi) sans tirer les conséquences de ce nouveau traitement.

Le rôle de l'administrateur informatique est essentiel. Celui-ci doit signer une clause de confidentialité et il est recommandé de lui soumettre une charte Administrateur dédiée.

Les administrateurs peuvent, selon leur habilitation, être affectés à un certain nombre de missions comme :

- la gestion, l'exploitation et la maintenance du système d'information ;
- le suivi et le contrôle de l'utilisation des ressources informatiques ;
- la mise en œuvre des logiciels et autres applications.

À ce titre, ils peuvent donc disposer de droits étendus quant à l'utilisation et à la gestion du système d'information et de communications électroniques.

Ainsi, ils pourront être amenés à avoir accès aux informations et/ou données d'autres utilisateurs susceptibles de présenter un caractère confidentiel ou privé.

Une charte Administrateur s'inscrit dans le cadre de la mise en place d'une politique de sécurisation et formalise les règles de déontologie et de sécurité spécifiques aux membres de la direction informatique ainsi qu'à l'ensemble des administrateurs et utilisateurs à hauts privilèges.

¹⁶ <https://www.cnil.fr/fr/securite-tracer-les-acces-et-gerer-les-incidents>

3.3. La valeur probatoire des éléments de journalisation

Une des conséquences de la collecte des éléments de journalisation est de permettre la traçabilité de l'activité d'un réseau et d'apporter la preuve de cette activité (utilisation ou non-utilisation d'une application ou d'un service par un utilisateur, accès illégitime, etc.). Une partie non négligeable de leur intérêt réside dans leur capacité à identifier directement ou indirectement un individu ou un équipement ayant participé à cette activité.

Afin d'être opposable en cas de contentieux, leur mise en œuvre doit respecter les règles relatives à l'administration de la preuve et les principes directeurs devant les juridictions judiciaires ou administratives (loyauté, intégrité, licéité, etc.).

Du point de vue du RSSI :

Signer et horodater les journaux dès leur création permet d'assurer leur intégrité et d'accroître leur valeur probatoire (recommandations Anssi et Cnil).

4. Informations sur les mentions légales

4.1. Cadre juridique

La mise en œuvre de tout dispositif de contrôle de salariés implique :

1. Le respect des libertés et droits fondamentaux des salariés, en particulier de leur vie privée ;
2. Le respect d'une obligation de loyauté envers les salariés concernés ;
3. L'information et la consultation des représentants du personnel sur le dispositif mis en place ;
4. Les dispositifs de contrôle utilisés sont susceptibles de requérir la mise en œuvre d'actions de mise en conformité supplémentaires (mise en balance des intérêts si la base légale retenue est l'intérêt légitime, réalisation d'une analyse d'impact sur la protection des données [AIPD] et consultation de la Cnil en cas de risque résiduel, etc.)

⇒ Cf. Fiche FAQ « [Quels sont les principes du règlement ?](#) »

4.2. Gestion de la sous-traitance

Faire appel à la sous-traitance, c'est accepter que des traitements soient réalisés sur un SI externe à l'organisation. Les journaux sont utiles à plusieurs niveaux :

- en prévention (le traitement est journalisé afin de prévenir par exemple un détournement du système) ;
- en détection (un SIEM remontera une alerte suivant les règles paramétrées) ;
- en réaction (l'objectif est d'analyser un incident ou une attaque *a posteriori*).

Dans le cas de la sous-traitance, seule la réaction sera possible, accentuée avec le RGPD qui renforce la coopération du sous-traitant.

Le responsable de traitement perd ici toute visibilité sur les journaux liés aux traitements sous-traités sur d'autres SI que les siens. Or, ce qui intéresse avant tout un responsable de traitement, c'est de prévenir les incidents.

N'ayant plus à sa disposition les journaux pour s'assurer que les traitements sont corrects, il doit donc déléguer cette supervision à son sous-traitant. Pour cela, il doit veiller à inclure des clauses contractuelles (audit, certifications de sécurité, etc.) afin de s'assurer que la sécurité de son sous-traitant est évaluée. Il doit également veiller à suivre, lors de comités réguliers, les incidents de sécurité que son sous-traitant pourrait avoir.

➔ Cf. Fiche FAQ « [Responsabilité des sous-traitants](#) »

4.3. Destinataires des données

La Cnil ainsi que la jurisprudence ont posé plusieurs principes applicables à la gestion des éléments de journalisation par des personnes habilitées (administrateurs, RSSI, gestionnaires de compte, etc.) :

- seules des personnes spécifiquement habilitées peuvent accéder aux éléments de journalisation ;
- l'accès doit être strictement limité à la finalité poursuivie, de la manière la moins intrusive possible pour les données à caractère personnel ;
- le personnel habilité est soumis à des obligations de confidentialité particulières et ne doit divulguer aucune donnée à caractère personnel à l'exception de cas limités liés au fonctionnement technique, à la sécurité des systèmes ou aux intérêts de l'entreprise ;
- le personnel habilité ne doit subir aucune contrainte quant au dévoilement des informations, notamment par son employeur, sauf si la loi en dispose autrement (dans le cadre d'une procédure judiciaire).

5. Durée de conservation des données

La durée de conservation des fichiers de journaux peut être soumise à des contraintes légales et réglementaires sectorielles. Il convient d'en prendre connaissance pour définir les moyens techniques nécessaires à l'archivage des journaux.

La Cnil¹⁷ considère que les logs de connexion ne doivent pas être conservés plus de six mois sauf si d'autres contraintes réglementaires spécifiques s'appliquent.

La durée de **conservation maximale des logs prévue par la loi** est de **un an** (en référence au CPCE¹⁸ et au décret n° 2011-219 relatif à la conservation et à la communication des données permettant d'identifier toute personne ayant contribué à la création d'un contenu mis en ligne¹⁹).

Il est rappelé que chaque réglementation ou standard définit ses propres exigences.

Les organisations peuvent également être assujetties à des exigences complémentaires liées à leur secteur d'activité en matière de traçabilité et d'archivage, notamment lorsqu'ils exercent leur activité dans un secteur régulé.

¹⁷ <https://www.cnil.fr/fr/les-durees-de-conservation-des-donnees>

¹⁸ https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000028345210/

¹⁹ <https://www.legifrance.gouv.fr/loda/id/JORFTEXT000023646013/> (article 3)

Par exemple, pour les moyens de paiement, la conservation d'une trace d'audit est requise **pendant au moins un an**, avec un minimum de trois mois de trace immédiatement accessible d'après la section 10.7 de la *Norme de sécurité de l'industrie des cartes de paiements PCI DSS*²⁰.

En France, les opérateurs d'importance vitale (OIV) doivent conserver **pendant une durée d'au moins six mois** les événements enregistrés par le système de journalisation de leurs systèmes d'information d'importance vitale (SIIV)²¹. Des arrêtés sectoriels définissent les obligations pour chaque famille d'opérateur²² (« Audiovisuel et information », « Communications électroniques et Internet », « Industrie » et « Finances »).

En France toujours, les opérateurs de service essentiels (OSE) doivent conserver « les événements enregistrés par le système de journalisation [...] pendant une durée d'au moins six mois ». (Cf. 8.1. « Opérateur service essentiel »).

Enfin, l'Autorité nationale des jeux (ANJ) doit pouvoir accéder pour le secteur des jeux en ligne²³ aux données archivées. Les archives **doivent couvrir au moins les douze derniers mois d'activité de l'opérateur**.

Il est donc vivement recommandé d'effectuer un état des lieux de la réglementation sectorielle applicable pour son système d'information.

Récapitulatif

Régime juridique	Fondement	Public concerné	Type de données concernées	Durée de rétention
Données à caractère personnel	Doctrine de la Cnil, Guide de sécurité, Fiche 4 « Tracer les accès et gérer les incidents » ²⁴	Responsables de traitement de données à caractère personnel	Données à caractère personnel (durée de conservation minimale)	Six mois au plus (sauf obligation légale, ou risque particulièrement important)
Communications électroniques	Code des postes et des communications électroniques (Art. 34-1 et R.10-13, III)	Toute personne qui, au titre d'une activité professionnelle principale ou accessoire, offrant au public une connexion permettant une communication en ligne par l'intermédiaire d'un accès à un réseau, y compris à titre gratuit	Identification des personnes, caractéristiques techniques des communications, localisation des équipements terminaux. Recherche et poursuite d'une infraction	Un an

²⁰ https://fr.pcisecuritystandards.org/_onelink_/pcisecurity/en2frfr/minisite/en/docs/PCI_DSS_v3-2-1_FR.pdf

²¹ <https://www.legifrance.gouv.fr/loda/id/JORFTEXT000033521327> (5. Règle relative à la journalisation)

²² <https://www.ssi.gouv.fr/actualite/cybersecurite-des-oiv-de-nouveaux-arretes-sectoriels/>

²³ <https://www.legifrance.gouv.fr/loda/id/JORFTEXT000022235495> (article 28)

²⁴ <https://www.cnil.fr/fr/securite-tracer-les-acces-et-gerer-les-incidents>

Fournisseur d'accès à Internet (FAI)	Art. 6. II de la loi n° 2004-575 du 21 juin 2004 modifiée (LCEN) ; Décret n° 2011-219	Personnes dont l'activité est d'offrir un accès à des services de communication au public en ligne	Données de connexion permettant d'identifier les personnes à l'origine du contenu	Un an
Hébergeurs	Art. 6. II de la loi n° 2004-575 du 21 juin 2004 modifiée (LCEN) ; Décret n° 2011-219	Personnes offrant, même à titre gratuit, le stockage de signaux, d'écrits, d'images, de sons ou de messages de toute nature aux destinataires de ces services	Données de connexion permettant d'identifier les personnes à l'origine du contenu	Un an

Pour les besoins de lutte contre les cybermenaces et dans le cadre de l'intérêt légitime, il est possible de justifier de durées de conservation plus longues, par exemple pour répondre à l'analyse des attaques persistantes (APT). Il convient alors de l'argumenter dans la documentation du traitement, au titre de l'*accountability*. Des mesures d'accompagnement seront à prévoir (accès restreint et sécurisé aux données, AIPD, etc.).

Enfin, au-delà de la durée de conservation des journaux, il convient de se poser la question de leurs modalités de conservation (archivage intermédiaire)^{25,26}.

6. Les risques liés à la mise en place d'une journalisation

Peuvent être ici notamment cités les risques suivants (non exhaustif) :

- risque de **non-conformité aux obligations légales et réglementaires** de respect de la vie privée et de la protection des données à caractère personnel (*RGPD, LIL modifiée*) ;
- risque de **litige avec les partenaires sociaux** (*Code du travail, art. L. 2312-38*) ;
- risque de **profilage** (corrélation des données *via* les SIEM) ;
- risque de **détournement de finalité** (ex. : traitement de journalisation ayant pour finalité la surveillance du système, utilisé par un service de ressources humaines pour suivre les horaires des collaborateurs) ;
- risque d'exploitation des données de collecte par un tiers (par espionnage ou exfiltration) ;
- risque **d'intégrité** (modification, destruction) **des journaux** en cas de journalisation opposable ;
- risque **d'inefficacité** (volumétrie, capacité d'analyse par les ressources, etc.) ;
- risque de **coût** (nombres d'équipements à surveiller [type IoT], duplication des journaux, durée de rétention, etc.).

²⁵ <https://www.cnil.fr/fr/comment-concilier-les-durees-de-conservation-et-les-archives>

²⁶ <https://www.cnil.fr/fr/securite-archiver-de-maniere-securisee>

6.1. Le détournement de finalité, conséquence d'une utilisation inappropriée d'un élément du SI

Principe

- Pas de collecte à des fins de contrôle (soit directement en accédant aux systèmes de logs ou indirectement par le biais de *reporting* par exemple).
- Possibilité de collecte pour garantir le bon usage des moyens informatiques (par exemple via la remontée d'informations dans un outil de *monitoring*). Ces mécanismes de contrôle doivent respecter certains principes tels que la proportionnalité et le respect de la vie privée des salariés.
- Il convient que la charte informatique précise les cas d'utilisation ainsi que la tolérance pour un usage personnel²⁷.

Exemples de jurisprudence :

• Contrôle des horaires

La Cnil a récemment mis en demeure plusieurs employeurs de mettre fin au contrôle des horaires de travail de leur personnel par le biais d'un système de badge intégrant une prise de photographie systématique des utilisateurs à chaque pointage. Une telle collecte de données apparaît excessive et contraire au règlement européen, souligne la Commission dans un communiqué diffusé le 27 août 2020²⁸.

▪ Géolocalisation

L'utilisation d'un système de géolocalisation pour assurer le contrôle de la durée du travail n'est pas justifiée quand le salarié dispose d'une liberté dans l'organisation de son emploi du temps²⁹.

Pour exemple, un salarié, recruté en qualité de vendeur, a pris acte de sa rupture de contrat de travail quatorze ans après et a reproché à son employeur d'avoir calculé sa rémunération sur la base du système de géolocalisation de son véhicule. La justice lui a donné raison. Soumis à déplacements sur deux départements, son contrat de travail prévoyait une liberté d'organisation, à charge pour lui de respecter le programme fixé et d'établir un compte-rendu journalier. Au bout de treize ans, son employeur lui notifie la mise en place d'un système de géolocalisation sur son véhicule pour permettre l'amélioration du processus de production et une meilleure optimisation des visites effectuées.

Du point de vue du DPO :

Les éléments de journalisation ou logs de connexion qui permettent d'enregistrer la date, l'heure et la durée de connexion sont des traitements de données personnelles définis pour des finalités déterminées (cf. 3. « La finalité des logs »).

Il est recommandé la plus grande vigilance afin d'éviter tout détournement de finalité.

La réalisation d'une AIPD peut être nécessaire.

²⁷ <https://www.cnil.fr/fr/securite-informatique-sensibiliser-les-utilisateurs>

²⁸ <https://www.cnil.fr/fr/badgeuses-photo-mise-en-demeure-de-plusieurs-employeurs-pour-collecte-excessive-de-donnees>

²⁹ <https://www.legifrance.gouv.fr/juri/id/JURITEXT000024761408/>

6.2. Contrôle de l'utilisation d'Internet et de la messagerie

L'employeur peut contrôler et limiter l'utilisation d'Internet (dispositifs de filtrage de sites, détection de virus, etc.) et de la messagerie (outils de mesure de la fréquence des envois et/ou de la taille des messages, filtres « anti-spam », etc.).

Ce contrôle a pour objectifs de :

1. Assurer la sécurité des réseaux qui pourraient subir des attaques (*malware*, virus, cheval de Troie, etc.) ;
2. Limiter les risques d'une utilisation personnelle excessive (consultation de sa messagerie personnelle, achats en ligne, usage excessif des réseaux sociaux, etc.) ;
3. Bloquer les sites à contenu illicite (sites de piratages, etc.) ;
4. Intervenir promptement lors d'avertissement d'usages ou contenus illicites ou suspects (exfiltrations de données, etc.).

Pour rappel, la messagerie mise à disposition par l'employeur revêt un caractère professionnel. L'employeur peut y accéder et lire les messages, tout comme il peut prendre connaissance des sites consultés, y compris en dehors de la présence de l'employé, compte tenu de la présomption de caractère professionnel. Cette présomption s'applique lorsque les outils sont mis à la disposition du collaborateur par l'employeur en vue de l'exécution du contrat de travail³⁰. Cependant, cette présomption connaît des exceptions dont il convient de tenir compte.

À ce titre, même si la Cnil³¹ rappelle que les marque-pages ou favoris du navigateur ne constituent pas un espace personnel ou privé, et que l'employeur peut y accéder et donc les contrôler, il n'en demeure pas moins que le collaborateur a le droit au respect de sa vie privée même au travail. Il ressort de la jurisprudence française³² et européenne³³ que la terminologie utilisée par le collaborateur pour qualifier un fichier de personnel est importante. Ainsi, le fait de nommer un fichier avec son prénom ou ses initiales, ou de placer des éléments dans le dossier « Mes documents », ou encore de renommer son disque dur « D:/Données personnelles » ne suffit pas.

Dès lors, il est opportun de se référer à la charte informatique de l'entreprise. Cette dernière peut définir la terminologie à employer pour qu'un fichier privé du collaborateur soit considéré comme personnel et non accessible à l'employeur. Ainsi, l'employeur ne pourra accéder aux fichiers identifiés comme personnels par le collaborateur que dans trois cas³⁴ : si le collaborateur est présent, s'il est dûment appelé ou s'il existe un risque ou événement particulier.

S'agissant de ce dernier critère, la jurisprudence procède par exclusion afin de définir les hypothèses susceptibles de rentrer dans le champ de la notion de « risque ou événement particulier ». Cette notion s'analyse au cas par cas, d'autant plus qu'elle est appréciée strictement par les juges³⁵ puisqu'elle permet à l'employeur d'accéder aux données identifiées comme personnelles par le collaborateur hors de sa présence.

³⁰ Cour de cassation, chambre sociale 12 février 2013, n° 11-28649, 9 février 2010, n° 08-45253 ; chambre commerciale, 10 février 2015, n° 13-14779

³¹ <https://www.cnil.fr/fr/les-outils-informatiques-au-travail>

³² Cour de cassation, chambre sociale, 8 décembre 2009 n° 08-44.840 ; 21 octobre 2009 n° 07-43877 ; 10 mai 2012 n° 11-13884

³³ CEDH, 5^e sect., 22 février 2018, req. n° 588/13, Libert c. France

³⁴ Cour de cassation, chambre sociale, 17 mai 2005 n° 03-40017 ; 17 juin 2009 n° 08-40274 ; 11 décembre 2001 n° 99-43030.

³⁵ Cour de cassation, chambre sociale, 17 mai 2005, n° 03-40017

Cour de cassation, chambre sociale, 5 juillet 2011, n° 10-17.284³⁶

La cour permet à l'employeur de consulter courriels et fichiers informatiques « qui n'ont pas été identifiés comme personnels par le salarié ».

« Mais attendu que le salarié a droit, même au temps et au lieu du travail, au respect de l'intimité de sa vie privée³⁷ ; que si l'employeur peut toujours consulter les fichiers qui n'ont pas été identifiés comme personnels par le salarié, il ne peut les utiliser pour le sanctionner s'ils s'avèrent relever de sa vie privée. »

Cour de cassation, chambre sociale, 23 octobre 2019, n° 17-28.448³⁸

« Attendu qu'ayant constaté que les messages électroniques litigieux, échangés au moyen d'une messagerie instantanée, provenaient d'une boîte aux lettres électronique personnelle distincte de la messagerie professionnelle dont la salariée disposait pour les besoins de son activité, la cour d'appel en a exactement déduit qu'ils étaient couverts par le secret des correspondances ».

De ce fait, l'employeur ne peut pas prendre connaissance des messages émis ou reçus à partir d'une messagerie électronique personnelle, même installée sur l'ordinateur de travail du salarié.

7. Exemples de cas particuliers

7.1. Opérateur de service essentiel (OSE) et fournisseur de service numérique (FSN)

Dans le cadre de la transposition de la directive (UE) 2016/1148, ou « directive NIS³⁹ », la France a précisé les différentes règles relatives à la sécurité des réseaux et SI d'opérateurs dits « essentiels », ainsi que les dispositions relatives à la sécurité des réseaux et systèmes d'information des fournisseurs de service numérique au sein de la loi n° 2018-133⁴⁰ du 26 février 2018. Un cadre de gouvernance est ainsi défini autour de l'Anssi⁴¹.

Les deux nouveaux types d'opérateurs définis légalement sont régis par l'arrêté du 14 septembre 2018⁴² fixant les 23 règles de sécurité mentionnées à l'article 10 du décret n° 2018-384 du 23 mai 2018⁴³, relatif à la sécurité des réseaux et SI des OSE et des FSN.

La gestion des logs intervient au niveau de deux règles : celle encadrant la journalisation et celle relative à la corrélation et l'analyse de journaux.

³⁶ <https://www.legifrance.gouv.fr/juri/id/JURITEXT000024338621/>, confirmé par Cour de cassation, chambre sociale, 18 octobre 2011, n° 10-25.706.

³⁷ Cour de cassation, chambre sociale, 2 octobre 2001, n°99-42.942, arrêt Nikon (arrêt de principe) : <https://www.legifrance.gouv.fr/juri/id/JURITEXT000007046161/>

³⁸ <https://www.legifrance.gouv.fr/juri/id/JURITEXT000039307321/>

³⁹ <https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=OJ:L:2016:194:TOC>

⁴⁰ <https://www.legifrance.gouv.fr/loda/id/JORFTEXT000036644772/>

⁴¹ <https://www.ssi.gouv.fr/actualite/directive-nis-lanssi-accompagne-les-premiers-operateurs-de-services-essentiels/>

⁴² <https://www.legifrance.gouv.fr/loda/id/JORFTEXT000037444012/>

⁴³ <https://www.legifrance.gouv.fr/loda/id/JORFTEXT000036939971/>

▪ **Règle 19 : Journalisation**

« L'opérateur de services essentiels met en œuvre sur chaque système d'information essentiel (SIE) un système de journalisation qui enregistre les événements relatifs à l'authentification des utilisateurs, à la gestion des comptes et des droits d'accès, à l'accès aux ressources, aux modifications des règles de sécurité du SIE ainsi qu'au fonctionnement du SIE. Le système de journalisation contribue à la détection d'incidents de sécurité en collectant les données de journalisation. »

[...]

« Les **événements enregistrés** par le système de journalisation sont horodatés au moyen de sources de temps synchronisées. Ils sont, pour chaque SIE, centralisés et archivés **pendant une durée d'au moins six mois**. Le format d'archivage des événements permet de réaliser des recherches automatisées sur ces événements. »

▪ **Règle 20 : Corrélation et analyse de journaux**

« L'opérateur de services essentiels met en œuvre un système de corrélation et d'analyse de journaux qui exploite les événements enregistrés par le système de journalisation installé sur chacun des systèmes d'information essentiels (SIE), afin de détecter des événements susceptibles d'affecter la sécurité des SIE. Le système de corrélation et d'analyse de journaux contribue à la détection d'incidents de sécurité en analysant les données de journalisation. »

7.2. Fournisseurs d'accès d'Internet (FAI)

La loi régit les accès au réseau Internet offerts par des fournisseurs : ils doivent conserver les données techniques de leurs clients pour les transmettre aux autorités à leur demande.

Cadre légal

- **La LCEN du 21 juin 2004** impose aux FAI la conservation des données « *de nature à permettre l'identification de quiconque a contribué à la création du contenu ou de l'un des contenus des services dont elle est prestataire* » (article 6 II). Ainsi, le FAI doit, pour les besoins de la recherche, de la constatation et de la poursuite des infractions pénales, et dans le seul but de permettre la mise à disposition de l'autorité judiciaire d'informations, pouvoir « réidentifier » les données si l'autorité judiciaire lui en fait la demande.
- **La loi n° 2006-64 du 23 janvier 2006, relative à la lutte contre le terrorisme**, a étendu cette obligation à l'ensemble des personnes qui, au titre d'une activité professionnelle principale ou accessoire, offrent au public une connexion permettant une communication en ligne par l'intermédiaire d'un accès au réseau, y compris à titre gratuit.
- **L'article L. 34-1 du CPCE** soumet les personnes offrant au public à titre professionnel une connexion à l'Internet aux mêmes obligations que les opérateurs de communications électroniques classiques, s'agissant des obligations de conservation de données permettant l'identification des personnes utilisatrices des services fournis.

Qui est concerné ?

Il s'agit de toutes « *personnes qui, au titre d'une activité professionnelle principale ou accessoire, offrent au public une connexion permettant une communication en ligne par l'intermédiaire d'un accès au réseau, y compris à titre gratuit* ».

Fournir un accès Wi-Fi au public à partir d'une connexion Internet entraîne de respecter les mêmes responsabilités qu'un FAI. La disposition s'applique notamment :

- aux personnes dont l'activité même est d'offrir un service payant de connexion en ligne, que l'on qualifie généralement de « cybercafé » ;
- aux personnes qui offrent à leurs clients, dans un cadre public, ou à des visiteurs une connexion en ligne, tels les hôtels, les restaurants, les compagnies aériennes, etc. ;
- aux fournisseurs d'accès à des réseaux de communications électroniques accessibles via une borne WI-Fi, généralement par l'utilisation de cartes prépayées permettant d'accéder à ce réseau, mais parfois également à titre gratuit.

Types de données à conserver

Le décret du 24 mars 2006 a créé un nouvel article R. 10-13 du CPCE⁴⁴, décrivant les catégories de données à conserver par les opérateurs de communications électroniques et pour les besoins de la recherche, de la constatation et de la poursuite des infractions pénales.

Les données concernées sont, à titre d'exemple, les logs de connexion (heures de début et de fin et durée de la connexion), l'adresse IP. À noter que la conservation du contenu des correspondances (objet ou texte d'un email) ou des informations consultées (contenu des pages Internet visitées) est prohibée.

Durée de conservation des données

La durée de conservation des données mentionnées au présent article est de **un an à compter du jour de l'enregistrement**.

Accès aux éléments de journalisation

Les autorités judiciaires peuvent demander que les opérateurs de communications électroniques, les FAI ainsi que les fournisseurs d'hébergement soient astreints à leur fournir les éléments de journalisation tels que définis dans la réglementation.

Depuis la promulgation de la loi relative à la lutte contre le terrorisme (2006), l'accès aux logs par les autorités policières n'est plus soumis à l'autorisation d'un magistrat, mais à celle d'un haut fonctionnaire de la police nommé par la Commission nationale de contrôle des interceptions de sécurité (CNCIS).

Sanction

- Article L. 39-3 du CPCE : « *Est puni d'un an d'emprisonnement et de 75 000 euros d'amende le fait pour un opérateur de communications électroniques ou ses agents [...] de ne pas procéder à la conservation des données techniques dans les conditions où cette conservation est exigée par la loi.* »
- Article L. 39-4 du CPCE : « *Sera puni de trois mois d'emprisonnement et de 30 000 euros d'amende ou de l'une de ces deux peines seulement quiconque aura, sans raison valable, refusé de fournir les informations ou documents ou fait obstacle au déroulement des enquêtes mentionnées aux articles L. 32-4, L. 40 et L. 43.* »

7.3. Protection de la création sur Internet – Cas Hadopi

La loi du 12 juin 2009 (dite « loi Hadopi ») favorisant la diffusion et la protection de la création sur Internet a modifié l'article L. 34-1 du CPCE de façon à permettre aux opérateurs de

⁴⁴ https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000025622766

communications électroniques de transmettre les données à caractère personnel et informations relatives à leurs abonnés à l'autorité administrative Hadopi.

Depuis la loi du 23 janvier 2006, les « fournisseurs de Wi-Fi » sont soumis aux mêmes obligations que les opérateurs de communications électroniques classiques et peuvent être amenés à répondre à une réquisition adressée par l'Hadopi.

Pour autant, il ne résulte ni de l'article L. 34-1 ni de l'article R. 10-13 du CPCE une obligation pour ces fournisseurs d'identifier les utilisateurs ni de se faire communiquer préalablement à la connexion leurs noms, prénoms, adresses et coordonnées téléphoniques, données pour autant attendues par Hadopi. Ils ne seront donc pas toujours en mesure de communiquer les données prévues par le décret du 5 mars 2010⁴⁵, mais uniquement des « données de trafic » ne permettant pas, pour le moins directement, d'établir une correspondance avec l'internaute contrevenant.

L'accès aux données de connexion des internautes par une autorité administrative sans contrôle judiciaire est jugé non conforme à la Constitution par le Conseil constitutionnel en 2015⁴⁶. Cette décision est prononcée à l'encontre des accès accordés aux agents de l'Autorité de la concurrence. Cette décision sera réitérée en 2017⁴⁷ pour les accès accordés à l'Autorité des marchés financiers et en 2019 pour les accès accordés aux agents des Douanes⁴⁸ ou de la sécurité sociale⁴⁹.

Le 20 mai 2020, le Conseil constitutionnel a ainsi rendu une décision analogue vis-à-vis des accès aux données de connexion demandées par Hadopi⁵⁰. L'article L. 331-21⁵¹ du Code de la propriété intellectuelle, genèse des lois Hadopi, est ainsi abrogé.

⁴⁵ <https://www.legifrance.gouv.fr/loda/id/JORFTEXT000021923996/>

⁴⁶ <https://www.conseil-constitutionnel.fr/decision/2015/2015715DC.htm>

⁴⁷ https://www.conseil-constitutionnel.fr/decision/2017/2017646_647QPC.htm

⁴⁸ <https://www.conseil-constitutionnel.fr/decision/2019/2018764QPC.htm>

⁴⁹ <https://www.conseil-constitutionnel.fr/decision/2019/2019789QPC.htm>

⁵⁰ <https://www.conseil-constitutionnel.fr/decision/2020/2020841QPC.htm>

⁵¹ https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000020740267/

8. Pour aller plus loin

Différentes documentations de l'Anssi mais aussi du NIST pour la mise en œuvre d'un système de journalisation sont à prendre en compte pour garantir la sécurité des logs et leur valeur probatoire :

- <https://www.ssi.gouv.fr/guide/recommandations-de-securite-pour-la-mise-en-oeuvre-dun-systeme-de-journalisation/>
- https://www.ssi.gouv.fr/uploads/IMG/pdf/NP_Journalisation_NoteTech.pdf
- https://www.ssi.gouv.fr/uploads/2014/12/RGS_P_Horodatage-Type_v2-3.pdf
- <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-92.pdf>

La Cnil lance une consultation publique pour un projet de recommandation relative aux mesures de journalisation. Cette consultation est ouverte jusqu'au 23 juillet 2021.
<https://www.cnil.fr/fr/consultation-publique-projet-de-recommandation-journalisation>

Elle propose aussi des documentations sur le sujet :

- https://www.cnil.fr/sites/default/files/atoms/files/cnil_guide_securite_personnelle.pdf
- <https://www.cnil.fr/fr/securite-tracer-les-acces-et-gerer-les-incidents>
- <https://www.cnil.fr/fr/les-outils-informatiques-au-travail>
- <https://www.cnil.fr/fr/lanonymisation-de-donnees-personnelles>
- https://www.cnil.fr/sites/default/files/atoms/files/projet_de_recommandation_-_journalisation.pdf

À suivre aussi l'actualité de la CJUE sur l'opposition aux législations nationales qui prévoient, à titre préventif, une conservation généralisée et indifférenciée des données relatives au trafic et des données de localisation à des fins judiciaires ou de renseignement :

- Arrêt du 6 octobre 2020 : <https://curia.europa.eu/jcms/upload/docs/application/pdf/2020-10/cp200123fr.pdf>
- Arrêt du 2 mars 2021 : <http://curia.europa.eu/juris/liste.jsf?language=fr&num=C-746/18>

Enfin, il existe des réglementations sectorielles qui imposent des obligations au titre de la gestion des logs, n'hésitez pas à les consulter si vous êtes concernés :

- PCI-DSS : <https://fr.pcisecuritystandards.org>
- SOX : <https://sarbanes-oxley-101.com/>
- HIPAA : <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity/index.html>

9. Acronymes

ACPR – Autorité de contrôle prudentiel et de résolution

AIPD – Analyse d'impact sur la protection des données

Anssi – Agence nationale de la sécurité des systèmes d'information

APT – *Advanced Persistent Threat*

CJUE – Cour de justice de l'Union européenne

CNCIS – Commission nationale de contrôle des interceptions de sécurité

Cnil – Commission nationale de l'informatique et des libertés

CPCE – Code des postes et des communications électroniques

DPO – *Data Protection Officer* (délégué à la protection des données)

FAI – Fournisseur d'accès Internet

Hadopi – Haute Autorité pour la diffusion des œuvres et la protection des droits sur Internet

HIPAA – *Health Insurance Portability and Accountability Act*

LCEN – Loi pour la confiance dans l'économie numérique

LIL – Loi Informatique et Libertés : loi n° 78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés dans sa version modifiée par l'ordonnance 2018-1125 du 12 décembre 2018 prise en application de l'article 32 de la loi 2018-493 du 20 juin 2018 relative à la protection des données personnelles

NTP – *Network Time Protocol*

OIV – Opérateur d'importance vitale

OSE – Opérateur de service essentiel

OSSIR – Observatoire de la sécurité des systèmes d'information et des réseaux

PCI-DSS – *Payment Card Industry Data Security Standard*

RGPD – Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016 relatif à la protection des données à caractère personnel et à la libre circulation de ces données et abrogeant la directive 95/46/CE (*règlement général sur la protection des données*)

RSSI – Responsable de la sécurité des systèmes d'information

RT – Responsable de traitement

SIEM – *Security Information and Event Management*

SOX – *Sarbanes-Oxley*

ST – Sous-traitant



L'ESPRIT DE L'ÉCHANGE

CLUB DE LA SÉCURITÉ DE L'INFORMATION FRANÇAIS

11 rue de Mogador

75009 Paris

France

☎+33 1 53 25 08 80

clusif@clusif.fr

Téléchargez toutes les productions du CLUSIF sur

www.clusif.fr
